



郑州大学
Zhengzhou University

第四单元 哈希函数与消息认证码

郑州大学网络空间安全学院

王志华

王志华



第4单元 哈希函数与消息认证码

提纲

CONTENTS

4.1 哈希函数概述

4.2 MD算法

4.3 SHA算法

4.4 MAC

4.5 SM3

4.6 其他哈希函数

2022/4/13



第4单元 哈希函数与消息认证码

提纲

CONTENTS

4.1 哈希函数概述

4.2 MD算法

4.3 SHA算法

4.4 MAC

4.5 SM3

4.6 其他哈希函数

2022/4/13

4.1 哈希函数概述



4.1.1 安全哈希函数需求

- ◆ 信息安全的三个要点
 - ◆ 机密性
 - ◆ 完整性
 - ◆ 可用性
- ◆ 加密算法解决了机密性问题，能否解决完整性问题？
 - ◆ 数据完整性是抗击对消息未授权修改的安全服务。
 - ◆ 有些应用不需要机密性，比如电子交易信息。
- ◆ 如何解决完整性问题：附加冗余
 - ◆ 对称技术：Hash函数(散列函数)，报文鉴别码（MAC）。
 - ◆ 非对称技术：数字签名

2022/4/13



1、非密码学中的哈希函数

- 数据 $X = (X_0, X_1, X_2, \dots, X_{n-1})$, 每一个 X_i 为一字节
 - 假设 $\text{hash}(X) = (X_0 + X_1 + X_2 + \dots + X_{n-1}) \bmod 256$
 - 这样安全吗?
- 实例: $X = (10101010, 00001111)$
 - 哈希值为 $10111001 (10101010 + 00001111) \% 256$
 - 那么 $Y = (00001111, 10101010)$ 的哈希值同上
 - 很容易找到碰撞 (冲突), 因此不安全...



1、非密码学中的哈希函数

- 数据 $X = (X_0, X_1, X_2, \dots, X_{n-1})$
 - 假设哈希值是
$$h(X) = nX_0 + (n-1)X_1 + (n-2)X_2 + \dots + 1 \cdot X_{n-1}$$
 - 这样安全吗?
- 至少
 - $h(10101010, 00001111) \neq h(00001111, 10101010)$
 - 但 $(00000001, 00001111)$ 的哈希值与 $(00000000, 00010001)$ 的哈希值相同, 因此不安全
- 因此非密码学中的哈希函数不是单向的, 因此不安全。
但可用在其他特定的应用中, 比如查找!



2、安全哈希函数的设计需求

●安全哈希函数的设计需求：

- ① 对于任意的输入 X ，能够产生**较短的定长输出** $H(X)$ ，并且 $H(X)$ 的**计算是容易的**。
- ② 输出对输入必须具有**敏感性**，即输入数据的任意一点改变（通常指二进制数据中任一比特的改变），都将在输出值中反映出来，从而产生不同的输出。
- ③ **碰撞是不容易的**，即找到 $X \neq Y$ 使 $H(X) = H(Y)$ 是十分困难的，即在**计算上是不可行的**。
- ④ **求逆是不容易的**，即不能由输出反求输入，或者说，由 $H(X)$ **计算 X 在计算上是不可行的**。

王卫华



3、安全哈希函数的设计原则

- 密码学中的hash函数 $h(x)$ 必须满足以下特性：
 - ① 压缩(Compression) — 输出长度很小
 - ② 有效率(Efficiency) — 对任意 x , $h(x)$ 容易计算
 - ③ 单向(One-way) — 对于给定 y 值, 很难找到 x 满足 $h(x) = y$
 - ④ 弱抗碰撞性(Weak collision resistance) — 给定 x 和 $h(x)$, 在计算机上找不到合适的 y 满足 $h(y) = h(x)$ 且 $y \neq x$
 - ⑤ 强抗碰撞性(Strong collision resistance) — 对任何 x 和 y , 计算机上找不到当 $x \neq y$ 时 $h(x) = h(y)$

2022/4/13

4.1 哈希函数概述



4.1.2 哈希函数基本概念

- ❖ **Hash**函数常用来构造数据的短“指纹”：消息的发送者使用所有的消息产生一个附件也就是短“指纹”，并将该短“指纹”与消息一起传输给接收者。
- ❖ 即使数据存储在不安全的地方，接收者重新计算数据的指纹，并验证指纹是否改变，就能够检测数据的完整性。这是因为一旦数据在中途被破坏，或改变，短指纹就不再正确。

2022/4/13



1、哈希函数定义

- 哈希函数H是一**公开函数**，用于将任意长的消息M**映射（压缩）**为较短的、固定长度的一个**值H(M)**，作为**认证符**。
 - 哈希函数H是对报文的一种固定长度的**不可恢复性压缩**，也是对报文内容的一种**摘要**。
 - 哈希函数H也被称为散列函数，杂凑函数，压缩函数，指纹函数，消息摘要函数等。
 - 函数值H(M)也被称为哈希值（Hash值），杂凑值，散列值，哈希码，消息摘要，数字指纹。
 - 哈希值H(M)是消息中**所有比特的函数**，因此提供了一种错误检测能力，即改变消息中任何一个比特或几个比特都会使哈希码发生改变。

王卫华



1、哈希函数的定义：示例

- ◆带密钥的Hash函数：可将h和消息M一起在不安全的信道中传输
- ◆不带密钥的Hash函数：h必须安全存放，确保h不被篡改。

消息M

散列值h

Hello Jerry, this is Tom speaking

0a35 bc9d 87e2 1a9f 54a4 8856 ef21

Hello Tom

77da ba15 e5c9 42f7 91ae bc28 4c39

2022/4/13



2、哈希函数的作用

❖ **Hash**函数最主要的作用于是用于鉴别，鉴别在网络安全中起到举足轻重的地位。鉴别的目的有以下两个：第一，验证信息的发送者是真正的，而不是冒充的，同时发信息者也不能抵赖，此为信源识别；第二，验证信息完整性，在传递或存储过程中未被篡改，重放或延迟等。

2022/4/13



2、哈希函数的作用

◆ 检测软件是否被篡改

精简版: [下载地址1] [下载地址2]

完整版: [下载地址1] [下载地址2]

md5sum如下: (下载完请校验一下)

4a846ca049c11be29b0402da40691ebe RedFlag-6.3-FullRepo-1.791-201008171700.iso

713ac4d06d4efd5cb5caf01dd8f3bfef RedFlag-6.3-Sys-1.791-201008171055.iso

完整版大小: 4.0G

精简版大小: 2.3G

软件下载:  下载地址1  下载地址2



2、哈希函数的作用

◆ 口令保护

userid	password	username	lastlogintime
szhang	9a32d6eb092d	zhang san	2012-10-2 12:30:42
sli	5321b2a761e0	li si	2012-10-3 14:12:30
wwang	d50c2234e9f7	wang wu	2012-10-2 15:22:34

2022/4/13



2、哈希函数的作用

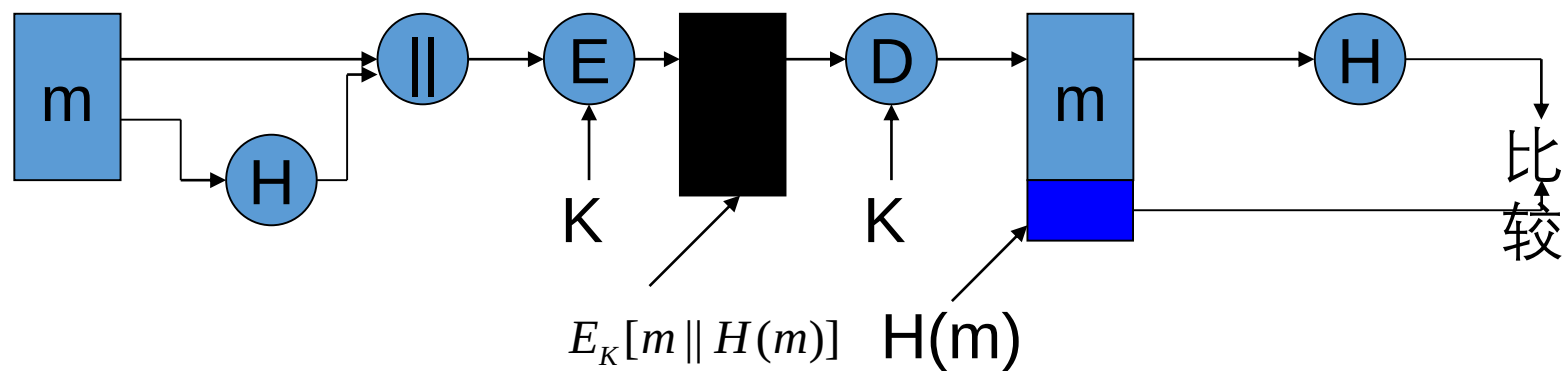
- 消息认证(HMAC)
- 消息完整性(HMAC)
- 信息指纹(签名)
- 侦测数据是否被破坏
- 提高数字签名的有效性
- 所有能够用对称密钥解决的问题
- 。 。 。 。 。

王华



2、哈希函数的作用

- 消息完整性认证：Hash，加密

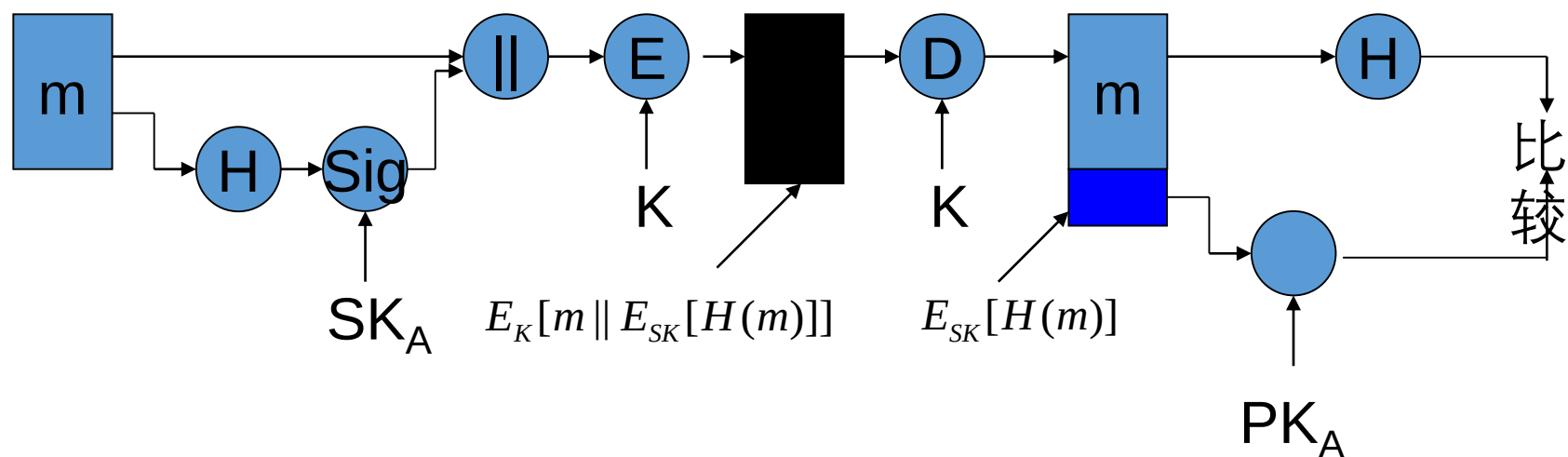


2022/4/13



2、哈希函数的作用

- 数字签名：hash，签名，加密



2022/4/13



2、哈希函数的作用：其他

●哈希函数还可以实现其他功能：基于计算过程和输出特征

➤生成**伪随机数**：生成具有**随机性质**的序列

➤密钥更新：由旧密钥计算得到**新的密钥**

➤。 。 。 。

王华



3、哈希函数的使用方式

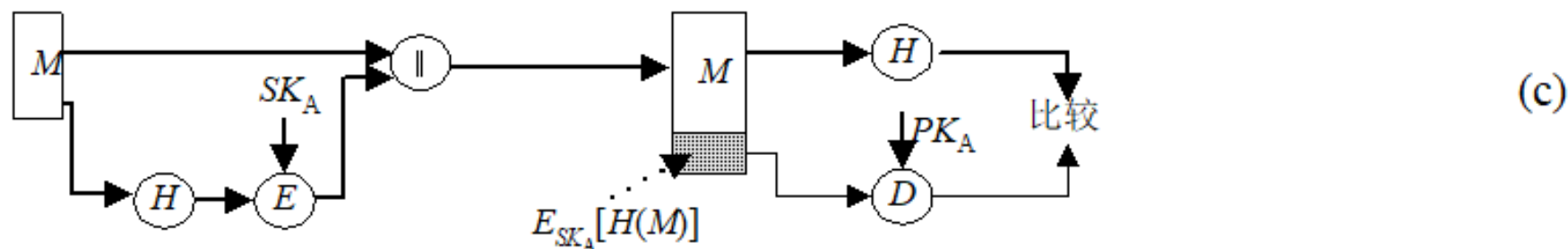
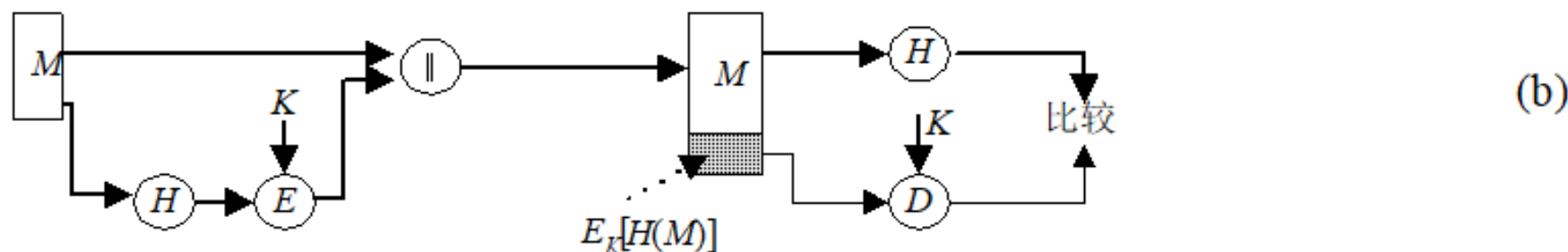
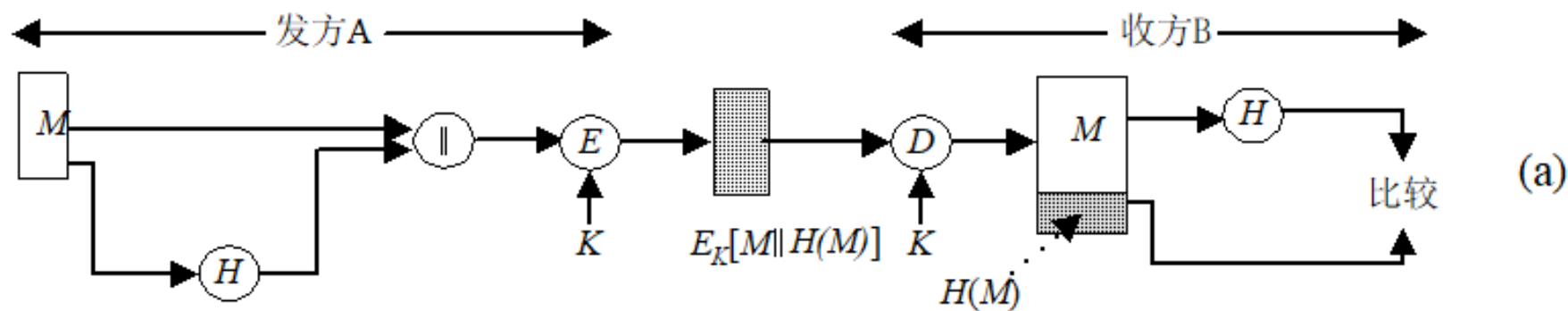
●哈希函数用来提供**消息认证**的基本使用方式，共有以下6种：第一部分密码学概论

- 重点思考每种使用方法都能**满足哪些安全需求**！
- 重点思考每种使用方法都能**抵抗哪些安全攻击**！
- 重点思考每种使用方法都能**提供哪些安全服务**！
- 重点思考每种使用方法都能**适用哪些应用场景**！

王卫华



3、哈希函数的使用方式



2022/4/13



3、哈希函数的使用方式

(1) 消息与哈希码链接后用单钥加密算法加密。由于所用密钥仅为收发双方A、B共享，因此可保证消息的确来自A并且**未被篡改**。同时还由于消息和哈希码都被加密，这种方式还提供了**保密性**。见图6-4 (a)。

(2) 用单钥加密算法仅对哈希码加密。这种方式用于**不要求保密性**的情况下可减少处理负担。注意这种方式与图6-1 (a) 的MAC结果完全一样，即将 $E_K[H(M)]$ 看作一个函数，函数的输入为消息M和密钥K，输出为固定长度。见图6-4 (b)。

王卫华



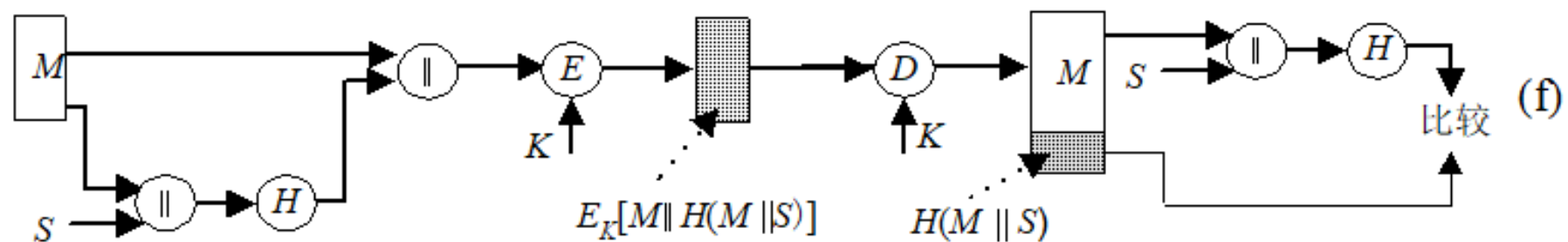
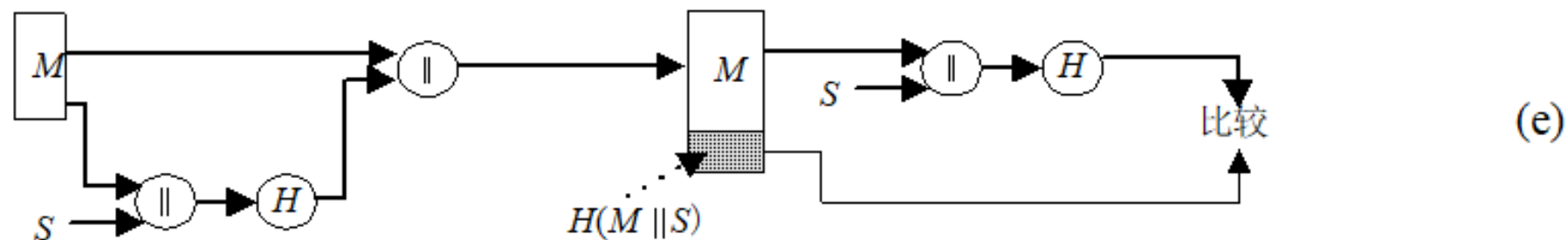
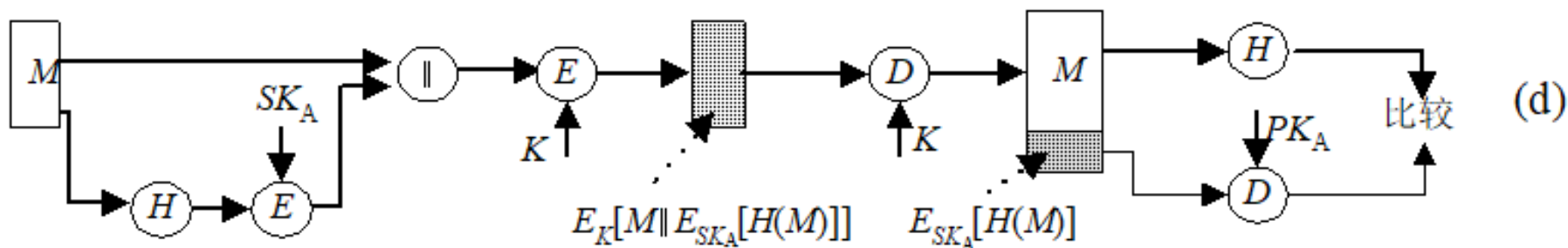
3、哈希函数的使用方式

(3) 用公钥加密算法和发方的秘密钥仅加密哈希码。和上一个2号模型一样，这种方式提供**认证性**，又由于只有发方能产生加密的哈希码，因此这种方式还对发方发送的消息提供了**数字签字**，事实上这种方式就是数字签字。见图6-4 (c)。

王卫华



3、哈希函数的使用方式



2022/4/13



3、哈希函数的使用方式

(4) 消息的哈希值用公钥加密算法和发方的秘密密钥加密后与消息链接，再对链接后的结果用单钥加密算法加密，这种方式提供了**保密性和数字签字**。见图6-4 (d)。

(5) 使用这种方式时要求通信双方**共享一个秘密值S**，A计算**消息M和秘密值S**链接在一起的哈希值，并将此哈希值附加到M后发往B。因B也有S，所以可重新计算哈希值以**对消息进行认证**。由于秘密值S本身未被发送，敌手无法对截获的消息加以篡改，也无法产生假消息。这种方式仅提供**认证**。见图6-4 (e)。

王卫华



3、哈希函数的使用方式

(6) 这种方式是在上一种模型中消息与哈希值链接以后再增加单钥加密运算，从而又可提供**保密性**。见图6-4 (f)。

- 在不要求保密性的情况下，**方式(2)和(3)将比其他方式更具有优势**：
 - 加密运算的速度较慢，代价较高
 - 加密算法受到专利保护

王卫华



4、哈希函数应满足的条件：6条

- 哈希函数的目的是为需认证的数据产生一个“**指纹**”。
- 为了能够实现对数据的认证，哈希函数应满足以下条件：
 - ① 函数的**输入可以是任意长**。
 - ② 函数的**输出是固定长**。
 - ③ 已知 x ，**求 $H(x)$ 较为容易**，可用硬件或软件实现。
 - ④ 已知 h ，求使得 $H(x)=h$ 的 x 在**计算上是不可行的**，这一性质称为**函数的单向性**，称 $H(x)$ 为**单向哈希函数**。
 - ⑤ **已知 x ，找出 $y(x)$ 使得 $H(y)=H(x)$ 在计算上是不可行的**。如果单向哈希函数满足这一性质，则称其为**弱单向哈希函数**。
 - ⑥ **找出任意两个不同的输入 x 、 y ，使得 $H(y)=H(x)$ 在计算上是不可行的**。如果单向哈希函数满足这一性质，则称其为**强单向哈希函数**。

王卫华



4、哈希函数应满足的条件：6条

●以上6个条件中：

- 前3个是哈希函数能用于**消息认证的基本要求**。
- 第4个条件（即**单向性**）则对**使用秘密值的认证技术**（看图6-4（e））极为重要。**假如哈希函数不具有单向性**，则攻击者截获M和 $C=H(S||M)$ 后，求C的逆 $S||M$ ，就可求出秘密值S。
- 第5个性质用于**抵抗第I类生日攻击**。
- 第6个性质用于**抵抗第II类生日攻击**。

2022/4/13



4、哈希函数应满足的条件：6条

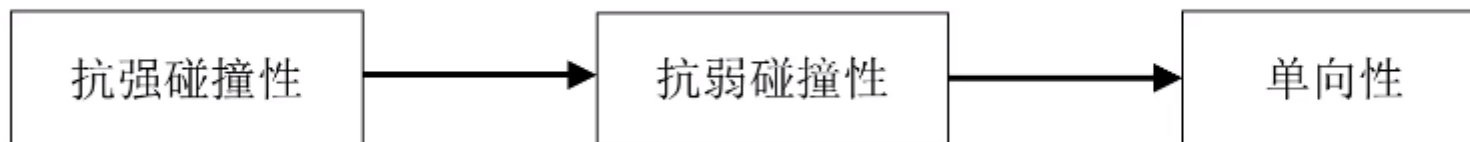
●以上6个条件中：

- 第5个条件使得敌手无法在已知某个消息时，找到与该消息具有相同哈希值的另一消息。
- 这一性质用于哈希值被加密情况时（看图6-4（b）和6-4（c））**防止敌手的伪造**，由于在这种情况下，敌手可读取传送的明文消息 M ，因此能产生该消息的哈希值 $H(M)$ 。
- 但由于敌手不知道用于加密哈希值的密钥，他就**不可能既伪造一个消息 M ，又伪造这个消息的哈希值加密后的密文**。
- 然而，如果第5个条件不成立，敌手在截获明文消息及其加密的哈希值后，就可按以下方式伪造消息：首先求出截获的消息的哈希值，然后产生一个具有相同哈希值的伪造消息，最后再将伪造的消息和截获的加密的哈希值发往通信的接收一方。

2024



4、哈希函数应满足的条件：6条



2022/4/13



5、哈希函数的分类：碰撞性

●性质5、6给出了哈希函数**无碰撞性**的概念：

- 如果哈希函数对**不同的输入可产生相同的输出**，则称该函数具有**碰撞性**。
- 在Hash函数中，如果有两个消息M1和M2，使得 $H(M1) = H(M2)$ ，则称这两个消息是**碰撞的**。

❖Hash函数的碰撞（collision）

设 x 、 x' 是两个不同的消息，如果

$$h(x) = h(x')$$

则称 x 和 x' 是Hash函数 h 的一个（对）碰撞。

2022/4/13



5、哈希函数的分类

❖ Hash函数的分类

- 单向Hash函数 (one-way)
 - 给定一个Hash值 y ，如果寻找一个消息 x ，使得 $y=h(x)$ 是计算上不可行的，则称 h 是单向Hash函数。
- 弱抗碰撞Hash函数 (weakly collision-free)
 - 任给一个消息 x ，如果寻找另一个不同的消息 x' ，使得 $h(x)=h(x')$ 是计算上不可行的，则称 h 是弱抗碰撞Hash函数。
- 强抗碰撞Hash函数 (strongly collision-free)
 - 如果寻找两个不同的消息 x 和 x' ，使得 $h(x)=h(x')$ 是计算上不可行的，则称 h 是强抗碰撞Hash函数。

2022/4/13



5、哈希函数的分类：强无碰撞hash函数

- 所谓**强无碰撞**（Collision-free，也称**碰撞自由**）的Hash函数，就是满足以下特点的单向函数：
 - 对任意长度的输入，产生一个固定长度的输出；
 - 由M计算H(M)是容易的；
 - 由输出无法（没有确定的算法）还原输入(单向性)；
 - 构造**两个不同的输入来产生相同输出，在计算上是不可行的**（概率极小）。
- 这样的函数也称为**强单向Hash函数**

王华



5、哈希函数的分类：弱无碰撞hash函数

●所谓**弱无碰撞**的Hash函数，就是满足以下特点的单向函数：

- 对任意长度的输入，产生一个固定长度的输出；
- 由M计算 $H(M)$ 是容易的；
- 由输出无法（没有确定的算法）还原输入(单向性)；
- 给定**一个随机选择的M1，构造M2**，使 $H(M1)=H(M2)$ ，在计算上是不可行的（概率极小）。

●这样的函数也称为**弱单向Hash函数**

王华



6、哈希函数的性质

- **hash**函数在现代密码学中起着重要的作用，主要用于对数据完整性和消息认证
 - 压缩性：任意长度的数据，算出的摘要长度都固定。
 - 容易计算：从原数据容易算出摘要。
 - 抗修改性：对原数据进行任何改动，哪怕只修改1个字节，所得到的摘要都有很大区别。
 - 弱抗碰撞：已知原数据和其摘要，想找到一个具有相同摘要的数据（即伪造数据），在计算上是困难的。
 - 强抗碰撞：想找到两个不同的数据，使它们具有相同的摘要，在计算上是困难的。



王华



6、哈希函数的性质

●Hash函数的性质

1. 应用需求

- 压缩性**: 对任意长度的消息 m 都可以产生固定长度的Hash值
- 易计算**: 对任意给定的消息 m , 它的哈希值 $H(m)$ 的计算相对简单

2. 安全意义

- 单向性**: 对于任意的Hash值 h , 要找到满足 $H(m)=h$ 的 m 在计算上不可行
- 弱无碰撞性**: 对于任意给定的 m_1 , 要找到满足 $H(m_2)=H(m_1)$ 且 $m_2 \neq m_1$ 的 m_1 在计算上不可行
- 强无碰撞性**: 要找到满足 $H(m_2)=H(m_1)$ 而 $m_2 \neq m_1$ 的消息对 (m_1, m_2) 在计算上不可行

2022/4/13

4.1 哈希函数概述



4.1.3 哈希函数的安全性

- 衡量一个Hash函数好坏的最好方法是，看一个敌手**找到一对碰撞消息**所花的**代价**，即**计算安全性**（**计算上不可行**！）。
- 通常都假设敌手已经知道Hash算法，即Hash函数是公开的，**对手目标**是**找到一对或更多对碰撞消息**，即**伪造消息**。
- 回忆“密码学概述”中“安全威胁模型”的概念。

王卫华



1、哈希函数的攻击方法

- ❖ 对Hash函数的攻击是指寻找一对碰撞消息的过程
- ❖ 与传统密码体制的攻击方式相比，对散列函数的攻击方法主要有两种：
 - 穷举攻击：它可以用于任何类型的散列函数的攻击，最典型的方式就是所谓的“生日攻击”。采用生日攻击的攻击者将产生许多明文消息，然后计算这些明文消息的指纹（摘要），进行比较。
 - 利用散列函数的代数结构：攻击其函数的弱性质。通常的有中间相遇攻击、修正分组攻击和差分分析攻击



uoy



2、日常生活中的生日问题

●生日问题的描述：

- 在一个教室中**最少应有多少学生**才能使得**至少有两个学生的生日在同一天**的**概率不小于 $1/2$** ？
- 在 **k 个人**中至少有两个人生日相同的概率大于二分之一时，那么 k 至少有多大？

王卫华



2、日常生活中的生日问题

- 假设一间房子里有N个人，N至少要多大才能满足N个人中有一个人和我生日相同的概率 $\geq \frac{1}{2}$
 - 一个人和我生日不同的概率是 $364/365 \rightarrow N$ 个人 $(364/365)^N$
 - 求解N : $1 - (364/365)^N = 0.5$
 - 找到 **N = 253**
- 一年365天，这个结果**看起来合理**！！！！

王卫华



2、日常生活中的生日问题

- 假设每人的生日在一年365天中任意一天是等可能的，即都等于 $1/365$ 。则，有多少人可以满足**两个或更多的人生日相同**的概率大于等于 $\frac{1}{2}$ ？

□那么随机选取 $n (< 365)$ 个人，生日各不相同：第一个人 $365/365$ ，第二个人 $364/365 \dots$

□ $1 - 365/365 \cdot 364/365 \cdot \dots \cdot (365 - N + 1) / 365$

□设定上式等于 $1/2$ 得到 **$N = 23$**

王华



2、日常生活中的生日问题

- “应该” 只需要365的平方根个人就能满足条件：
 - 对每两个人都比较了生日，一共做了 $N(N-1)/2$
($O(n^2)$) 次比较
 - 总共只有365种可能，那么只需 $N=\text{sqrt}(365)=19$ 个人就可以了

王华



3、哈希函数中的生日问题

- 哈希函数中的生日问题描述：
 - 已知一个哈希函数 H 有 n 个可能的输出（依赖固定长度）， $H(x)$ 是一个特定的输出，如果对 H 随机取 k 个输入，则至少有一个输入 y 使得 $H(y)=H(x)$ 的概率为0.5时， k 有多大？
 - 称对哈希函数 H 寻找上述 y 的攻击为第I类生日攻击。

王卫华



3、哈希函数中的生日问题

- 哈希函数中的生日问题分析：
 - 因为H有n个可能的输出，所以输入y产生的输出H(y)等于特定输出H(x)的概率是 $1/n$ ，反过来说 $H(y) \neq H(x)$ 的概率是 $1 - 1/n$ 。
 - y取k个随机值，而函数的k个输出中没有有一个等于H(x)，这个概率等于每个输出都不等于H(x)的概率之积，为 $[1 - 1/n]^k$ 。所以y取k个随机值得到函数的k个输出中至少有一个等于H(x)的概率为 $1 - [1 - 1/n]^k$

2022.4.13



3、哈希函数中的生日问题

➤ 因为 $(1+x)^k \approx 1+kx$, 当 $|x| \ll 1$;

得:

$$1 - [1 - 1/n]^k \approx 1 - [1 - k/n] = k/n$$

- 若使上述概率等于0.5, 则 $k = n/2$ 。
- 特别地, 如果H的输出为**固定的比特长度m**, 即可能的输出个数 $n = 2^m$, 则

$$k = 2^{m-1}$$

王华



4、生日悖论

❖ 生日悖论 (birthday paradox)

生日问题：假设每个人的生日是等概率的，每年有**365**天，在**k**个人中至少有两个人的生日相同的概率大于**1/2**，问**k**最小应是多少？

□ $k \geq 23$

□ 随机选择23个人，至少有两个人生日在同一天的概率不小于50%。

王华



4、生日悖论

- 为了回答这一问题，首先定义下述概率：设有 k 个整数项，每一项都在1到 n 之间等可能地取值，则 k 个整数项中至少有两个取值相同的概率为 $P(n, k)$ 。因而生日悖论就是求使得 $P(365, k) \geq 0.5$ 的**最小 k** 。
- 为此我们首先考虑 k 个数据项中任意两个取值都不同的概率，记为 $Q(365, k)$ 。
 - 如果 $k > 365$ ，则不可能使得任意两个数据都不相同，因此假定 $k \leq 365$ 。
 - k 个数据项中任意两个都不相同的所有取值方式数为：

$$365 \times 364 \times \cdots \times (365 - k + 1) = \frac{365!}{(365 - k)!}$$

王华



4、生日悖论

即第1个数据项可从365个中任取一个，第2个数据项可在剩余的364个中任取一个，依次类推，最后一个数据项可从365-k+1个值中任取一个。如果去掉任意两个都不相同这一限制条件，可得k个数据项中所有取值方式数为 365^k 。

所以可得：

$$Q(365, k) = \frac{365!}{(365 - k)! 365^k}$$

$$P(365, k) = 1 - Q(365, k) = 1 - \frac{365!}{(365 - k)! 365^k}$$

王卫华



4、生日悖论

k人生日都不同的概率是：

$$\left(1 - \frac{1}{365}\right) \left(1 - \frac{2}{365}\right) \cdots \left(1 - \frac{k-1}{365}\right).$$

k人中至少有2人生日相同的概率为：

$$P(365, k) = 1 - \left(1 - \frac{1}{365}\right) \left(1 - \frac{2}{365}\right) \cdots \left(1 - \frac{k-1}{365}\right).$$

2022



4、生日悖论

- 当 $k=23$ 时, $P(365, 23)=0.5073$, 即上述问题只需23人, 人数如此之少。
- 若 k 取100, 则 $P(365, 100)=0.9999997$, 即获得如此大的概率。
- 之所以称这—问题是**悖论**是因为当人数 k 给定时, 得到的至少有两个人的生日相同的概率**比我们想象的要大得多**。
- 这是因为在 k 个人中考虑的是任意两个人的生日是否相同, 在23个人中可能的情况数为 $C_{23}^2 = 253$ 。

王卫华



4、生日悖论

- 将生日悖论推广为下述问题：
 - 已知一个在1到n之间均匀分布的整数型随机变量，若该变量的k个取值中至少有两个取值相同的**概率大于0.5**，则k至少多大？
 - 与上类似， $P(n, k) = 1 - \frac{n!}{(n-k)!n^k}$ ，令 $P(n, k) > 0.5$ ，可得 $k = 1.18\sqrt{n} \approx \sqrt{n}$ 。
 - 若取 $n=365$ ，则 $k = 1.18\sqrt{365} = 22.54$ 。

王华



5、生日攻击：概述

❖生日攻击法

生日悖论原理可以用于构造对**Hash**函数的攻击

❖设**Hash**函数值有 n 个比特， m 是真消息， M 是伪造的假消息，分别把消息 m 和 M 表示成 r 和 R 个变形的消息。消息与其变形消息具有不同的形式，但有相同的含义。将消息表示成变形消息的方法很多，例如增加空格、使用缩写、使用意义相同的单词、去掉不必要的单词等。

2022



5、生日攻击：概述

- 如果 $h(x)$ 是 N 位，那么总共有 2^N 个不同可能哈希值
 $\text{sqrt}(2^N) = 2^{N/2}$
- 那么在计算 $2^{N/2}$ 个随机数时就可能碰到一次哈希值相同
- 暗示结论：
 - 穷举攻击：破解 **N 位对称密钥**需要的‘功’为 2^{N-1} ；而破解 **N 位hash函数**需要的‘功’为 $2^{N/2}$ ！
 - 破解哈希值比破解密钥容易的多得多！

王卫华



5、生日攻击：概述

- 生日攻击是基于下述结论：
 - 设哈希函数H有 2^m 个可能的输出（即输出长m比特），如果H的k个随机输入中至少有两个产生相同输出的概率大于0.5，则 $k \approx \sqrt{2^m} = 2^{m/2}$ 。
- 称寻找函数H的具有相同输出的两个任意输入的攻击方式为第II类生日攻击。

2022/4/13

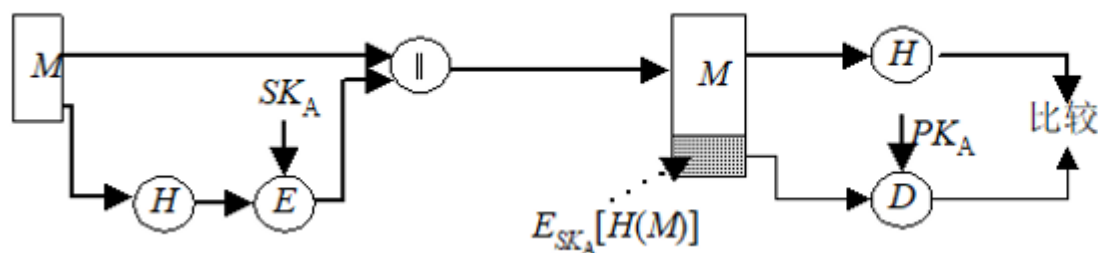


5、生日攻击：方式

第 II 类生日攻击可按以下方式进行：

(1) 设用户将用图6-4 (c) 所示的方式发送消息，即A用**自己的秘密钥**对消息的**哈希值加密**，加密结果作为对消息的**签名**，连同明文消息一起发往接收者。

(2) 敌手对A发送的消息M产生出 $2^{m/2}$ 个**变形的消息**，每个变形的消息本质上的含义与原消息相同，同时敌手还准备**一个假冒的消息（伪造）** M' ，并对假冒的消息产生出 $2^{m/2}$ 个变形的消息。



(c)

2022/4/13



5、生日攻击：方式

第 II 类生日攻击可按 ([1] 方式) 进行：

(3) 敌手在产生的两个消息集合中，找出**哈希值相同**的一对消息 $\tilde{M}, \tilde{M}$ ，由上述讨论可知敌手成功的概率大于 0.5。如果不成功，则**重新产生一个假冒的消息**，并产生 $2^{m/2}$ 个变形，直到找到哈希值相同的一对消息为止。

(4) 敌手将 $\tilde{M}$ 提交给 A 请求签字，由于 $\tilde{M}$ 与 $\tilde{M}$ 的哈希值相同，所以可将 A 对 $\tilde{M}$ 的签字当作对 $\tilde{M}$ 的签字，将此签字连同 $\tilde{M}$ 一起发给意欲的接收者。

● 寻求碰撞，签名伪造成功！！！！

王卫华



5、生日攻击：分析

上述攻击中如果哈希值的长为64比特，则敌手攻击成功所需的时间复杂度为 $O(2^{32})$

将一个**消息变形**为具有相同含义的另一消息的方法有很多，例如对文件，敌手可在文件的单词之间插入很多“space-space-backspace”字符对，然后将其中的某些字符对替换为“space-backspace-space”就得到一个变形的消息。

王华



5、生日攻击：分析

生日攻击隐含着消息摘要的长度的一个下界。一个40比特长的消息摘要是很不安全的，因为仅仅用 2^{20} （大约一百万）次随机Hash可至少以 $1/2$ 的概率找到一个碰撞。为了抵抗生日攻击，通常建议消息摘要的长度至少应取为128比特，此时生日攻击需要约 2^{64} 次Hash。安全的Hash标准的输出长度选为160比特是出于这种考虑。

王卫华



5、生日攻击：其他描述1

设 $h: X \rightarrow Y$ 是一个Hash函数， X 和 Y 都是有限的，并且 $|X| \geq 2|Y|$ ，记 $|X|=m$ ， $|Y|=n$ 。显然至少有 n 个碰撞，问题是如何去找到这些碰撞。一个很自然的方法是随机选择 k 个不同的元素 $x_1, x_2, x_3, \dots, x_k \in X$ ，计算 $y_i = h(x_i)$ ， $1 \leq i \leq k$ ，然后确定是否有一个碰撞发生。这个过程类似于把 k 个球随机地扔到 n 个箱子里边，然后检查是否某一箱子里边至少有两个球。 k 个球对应于 k 个随机数 $x_1, x_2, x_3, \dots, x_k$ ， n 个箱子对应于 Y 中的 n 个可能的元素。我们将计算用这种方法找到一个碰撞的概率的下界，该下界只依赖于 k 和 n ，而不依赖于 m 。

2022



5、生日攻击：其他描述1

因为我们关心的是碰撞概率的下界，所以可以假定对所有 $y \in Y$ ，有 $|h^{-1}(y)| \approx m/n$ 。这个假定是合理的，这是因为如果原像集 $h^{-1}(y)$ ($y \in Y$)不是近似相等的，那么找到一个碰撞的概率将增大。

因为原像集 $h^{-1}(y)$ ($y \in Y$)的个数都近似相等，并且 x_i ($1 \leq i \leq k$)是随机选择的，所以可将 $y_i = h(x_i)$ ($1 \leq i \leq k$)视作 Y 中的随机元素（ y_i ($1 \leq i \leq k$)未必不同）。但计算 k 个随机元素 $y_1, y_2, \dots, y_k \in Y$ 是不同的概率是一件容易的事情。依次考虑 $y_1, y_2, \dots, y_k$ 。 y_1 可任意地选择； $y_2 \neq y_1$ 的概率为 $1 - (1/n)$ ； $y_3 \neq y_1, y_2$ 的概率为 $1 - (2/n)$ ； $\dots$ ； $y_k \neq y_1, y_2, \dots, y_{k-1}$ 的概率为 $1 - ((k-1)/n)$ 。

2022/4/13



5、生日攻击：其他描述1

因此，没有碰撞的概率是 $(1-1/n) \times (1-2/n) \times \cdots \times (1-(k-1)/n)$ 。如果 x 是一个比较小的实数，那么 $1-x \approx e^{-x}$ ，这个估计可由下式推出： $e^{-x} = 1 - x + x^2/2! - x^3/3! + \cdots$ 。现在估计没有碰撞的概率 $(1-1/n)(1-2/n) \cdots (1-(k-1)/n)$ 约为 $e^{-k(k-1)/2n}$ 。我们设 ε 是至少有一个碰撞的概率，则 $\varepsilon \approx 1 - e^{-k(k-1)/2n}$ ，从而有 $k^2 - k \approx n \ln(1/(1-\varepsilon)^2)$ 。去掉 $-k$ 这一项，我们有 $k^2 \approx n \ln(1/(1-\varepsilon)^2)$ ，即 $k \approx \sqrt{n \ln(1/(1-\varepsilon)^2)}$ 。

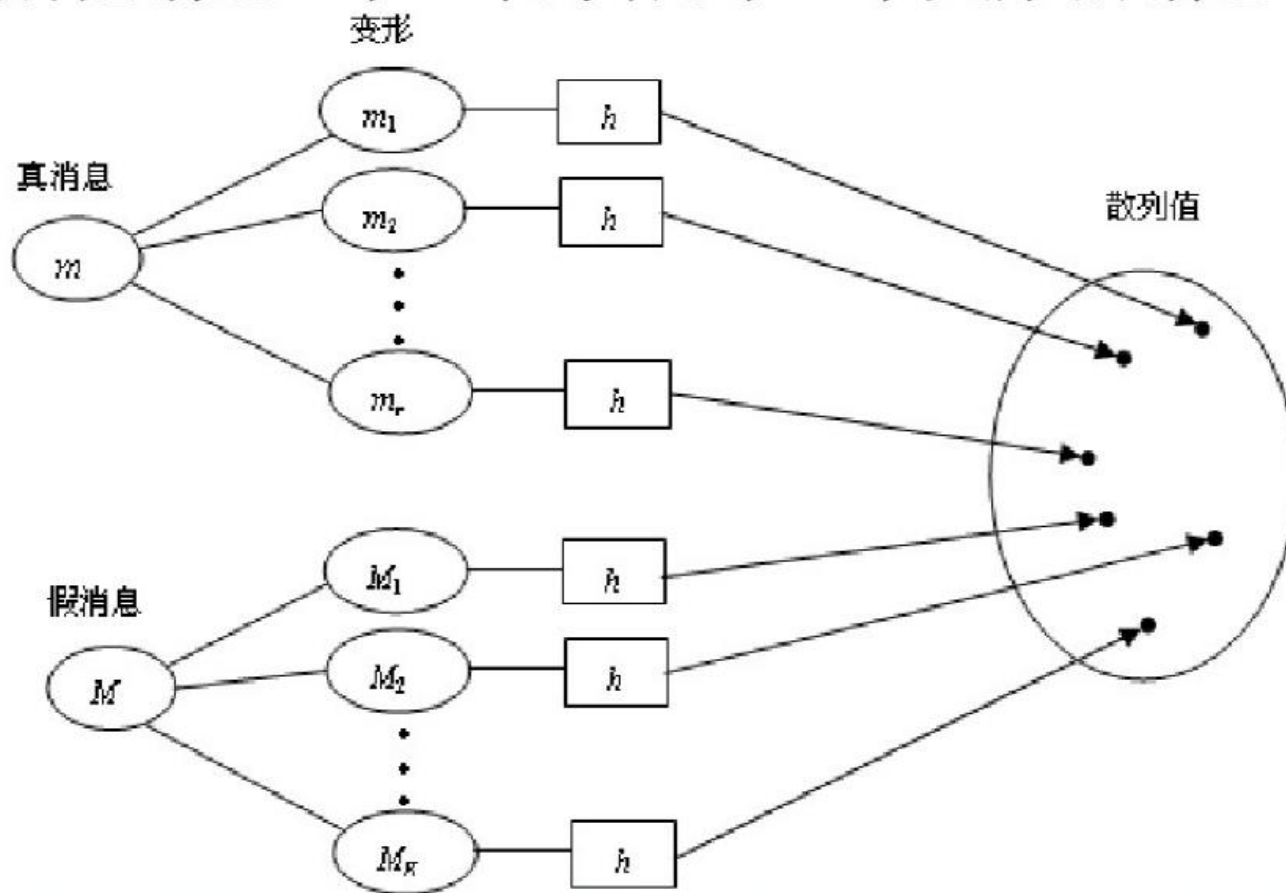
如果我们取 $\varepsilon=0.5$ ，那么 $k \approx 1.17 \sqrt{n}$ 。这表明，仅 $\sqrt{n}$ 个 X 的随机的元素就能以 50% 的概率产生一个碰撞。注意 ε 的不同选择将导致一个不同的常数因子，但 k 与 $\sqrt{n}$ 仍成正比例。

2022/4/13

5、生日攻击：其他描述2

❖ 生日攻击法

- 分别把消息 m 和 M 表示成 r 和 R 个变形的消息



2024



5、生日攻击：其他描述2

❖ 生日攻击法

- 计算真消息 m 的变形与假消息 M 的变形发生碰撞的概率

由于 n 比特长的散列值共有 2^n 个，所以对于给定 m 的变形 m_i 和 M 的变形 M_j ， m_i 与 M_j 不碰撞的概率是 $1-1/2^n$ 。由于 M 共有 R 个变形，所以 M 的全部变形都不与 m_i 碰撞的概率是：

$$\left(1 - 1/2^n\right)^R.$$

2022/4/13



5、生日攻击：其他描述2

因为消息 m 共有 r 个变形，因此 m 的变形与 M 的变形都不碰撞的概率是：

$$\left(1 - 1/2^n\right)^{rR}.$$

m 的变形与 M 的变形发生碰撞的概率是：

$$P(n) = 1 - \left(1 - \frac{1}{2^n}\right)^{rR} \approx 1 - e^{-\frac{rR}{2^n}}.$$

2024



5、生日攻击：其他描述2

❖生日攻击法

当 $r=R=2^{n/2}$ 时， $P(n)=1-e^{-1}\approx 0.63$ 。对于Hash值长度为64比特的Hash函数，生日攻击的时间复杂度约为 2^{32} ，所以是不安全的。

为了抵抗生日攻击，建议Hash值长度至少为128 比特。

王华



5、生日攻击：其他描述3

对任意函数 $f: X \rightarrow Y$ ，其中 Y 为包含 n 个元素的集合，考虑下面的问题：

对于一个概率界限 $\varepsilon (0 < \varepsilon < 1)$ ，找一个整数 k ，使得对于 k 个两两互异的值 $x_1, x_2, \dots, x_k \in X$ ， k 个函数值 $f(x_1), f(x_2), \dots, f(x_k)$ 对某些 $i \neq j$ 有

$Pr[f(x_i) = f(x_j)] \geq \varepsilon$ ，即在 k 个函数值中，以不小于 ε 的概率发生碰撞。

考虑随机性的函数：将 X 中均匀分布的输入映射到 Y 中均匀分布的输出
为了发生碰撞，要求 $|X| > |Y|$ 。

2022.4.13



5、生日攻击：其他描述3

想象往 n 个箱子中随机投 k 个球，检查是否有某个箱子装有至少两个球。
(k 个球对应于 k 个随机的 x_i ， n 则对应 Y 可能的 n 个元素。)

没有碰撞的概率：令 p_i 为投 i 个球还未碰撞的概率 $1 - x \approx e^{-x}$

$$p_1 = 1$$

$$p_2 = \frac{n-1}{n} p_1 = 1 - \frac{1}{n}$$

$$p_3 = \frac{n-2}{n} p_2 = (1 - \frac{1}{n})(1 - \frac{2}{n})$$

...

$$p_k = \frac{n-(k-1)}{n} p_{k-1} = (1 - \frac{1}{n})(1 - \frac{2}{n}) \cdots (1 - \frac{k-1}{n})$$

$$(1 - \frac{1}{n})(1 - \frac{2}{n}) \cdots (1 - \frac{k-1}{n}) \approx \prod_{i=1}^{k-1} e^{-\frac{i}{n}} = e^{-\frac{k(k-1)}{2n}}$$

至少有一个碰撞的概率为

$$1 - e^{-\frac{k(k-1)}{2n}} \geq \varepsilon$$

$$k \geq \sqrt{2n \ln \frac{1}{1-\varepsilon}}$$

取 $\varepsilon = \frac{1}{2}$ $k \geq 1.1774\sqrt{n}$ $n=365$ 有 $k \approx 22.49$

2022/4/13



5、生日攻击：其他描述3

$$k \geq \sqrt{2n \ln \frac{1}{1-\varepsilon}}$$

- ◆ 对一个输出空间大小为 n 的随机函数，只需计算大约 $\sqrt{n}$ 个函数值，就能以一个不可忽略的概率发现一个碰撞。
- ◆ Hash函数的输出空间大小必须有一个下界，长度为 $|h|$ 的Hash函数，只需要 $2^{\frac{|h|}{2}}$ 个随机哈希值就可以一个不可忽略的概率产生碰撞，目前至少为160比特，抗生日攻击的强度至少为 2^{80} 。

2022



5、生日攻击：其他描述3

- ◆ A准备两份合同M和M'，一份B会同意，一份会取走他的财产而被拒绝。
- ◆ A对M和M'各做32处微小变化(保持原意)，分别产生 2^{32} 个64位hash值。
- ◆ 根据前面的结论，超过0.5的概率能找到一个M和一个M'，它们的hash值相同。
- ◆ A提交M，经B审阅后产生64位hash值并对该值签名，返回给A。
- ◆ A用M'替换M。
- ◆ Hash必须足够长。

2022/4/13



5、生日攻击：算法

●攻击算法

- ① 随机选取 n 个消息 $m_1, m_2, \dots, m_n$;
- ② 计算相应的哈希值, 得到
 $S = \{ (m_k, H(m_k)) : k=1, 2, \dots, n \}$;
- ③ 根据 $H(m_k)$ 的大小对集合 S 进行快速排序, 并寻找使 $H(m_k) = H(m_t)$ 成立的不同消息 m_k 和 m_t ; 如果找到这样的 (m_k, m_t) , 也就是找到了碰撞, 算法终止。

王卫华



5、生日攻击：算法分析

●攻击算法的成功率分析

定理：设Hash函数H的Hash值为n比特，N是对H实施碰撞攻击所选取的消息数量，并且要求 $N \ll 2^{n/2}$ ，则生日攻击算法成功的概率近似为 $1 - e^{-\frac{N^2}{2^{n+1}}}$ 。

□取 $N = \sqrt{2^n}$ ，成功率为 $1 - e^{-0.5} \approx 0.393$ 。

□n至少为128比特。

2022



6、中间相遇攻击

- 中间相遇攻击是生日攻击的一种变形，这种攻击主要适用于攻击具有分组链结构的Hash方案。它不比较Hash值，而是比较链中的中间变量。
- 中间相遇攻击的基本原理为：将消息分成两部分，对伪造消息的第一部分从初试值开始逐步向中间阶段产生 r_1 个变量；对伪造消息的第二部分从Hash结果开始逐步退回中间阶段产生 r_2 个变量。在中间阶段有一个匹配的概率与生日攻击成功的概率一样。

2022/4/13



7、随机预言家模型

假定 $h: X \rightarrow Y, |X| \geq |Y|$, 设 $x \in X$, 定义 $y = h(x)$:

- ◆ 单向性（原像稳固）：给定消息摘要 y , 找到 x 使得 $h(x) = y$ 困难。
- ◆ 第二原像稳固：给定消息 x , 找到 $x' \neq x$, 使得 $h(x) = h(x')$ 困难。
- ◆ 碰撞稳固：找到 $x' \neq x$, 使得 $h(x) = h(x')$ 困难。

随机预言机ROM (Random Oracle Machine)

- ◆ Bellare和Rogaway提出
- ◆ 提供“理想” Hash函数的数学模型
- ◆ 确定性，有效性和均匀输出。

2022/4/13



7、随机预言家模型：定义及特性

令 $F^{X,Y}$ 是为所有从 $X \rightarrow Y$ 的函数集合，假定 $|X|=N$ ， $|Y|=M$ ，随机从 $F^{X,Y}$ 中选出一个 Hash 函数 $h: X \rightarrow Y$ ，对于任意的输入，其输出值是均匀的，且计算 $h(x)$ 的唯一方法是询问随机预言机。

假定 $h \in F^{X,Y}$ 是随机选择的，令 $X_0 \subseteq X$ ，假定当且仅当 $x \in X_0$ 时， $h(x)$ (通过查询 h 的预言机) 被确定，则对所有 $x \in X \setminus X_0$ 和 $y \in Y$ ，都有 $Pr[h(x) = y] = \frac{1}{M}$

2022.4.13



7、随机预言家模型：原像问题

Find-Preimage(h, y, Q)

选择任意的 $X_0 \subseteq X, |X_0| = Q$

for each $x \in X_0$

do $\begin{cases} \text{if } h(x) = y \\ \text{then return}(x) \end{cases}$

return(failure)

对于任意的 $X_0 \subseteq X$ 且 $|X_0| = Q$, 算法的平均成功率

$$\varepsilon = 1 - \left(1 - \frac{1}{M}\right)^Q$$

证明：给定 $y \in Y$, 令 $X_0 = \{x_1, x_2, \dots, x_Q\}$ 。

对于 $1 \leq i \leq Q$, 令 E_i 表示事件 “ $h(x_i) = y$ ”。

根据随机预言机的性质可知

对于所有 $1 \leq i \leq Q, \Pr(E_i) = \frac{1}{M}$,

E_i 独立, 则 $\Pr[E_1 \vee E_2 \vee \dots \vee E_Q] = 1 - \left(1 - \frac{1}{M}\right)^Q$

对任意给定的 y , 成功率是常数, 因此结论成立。

Q 远小于 M , 因此 $\varepsilon \approx \frac{Q}{M}$ 。

2022

7、随机预言家模型：第二原像问题



Find-2nd-Preimage(h, x, Q)

$y \leftarrow h(x)$

选择 $X_0 \subseteq X \setminus \{x\}, |X_0| = Q-1$

for each $x_0 \in X_0$

do $\begin{cases} \text{if } h(x_0) = y \\ \text{then return}(x_0) \end{cases}$

return(failure)

对于任意的 $X_0 \subseteq X \setminus \{x\}$, 且 $|X_0| = Q-1$,

算法的平均成功率 $\varepsilon = 1 - \left(1 - \frac{1}{M}\right)^{Q-1}$

2022



7、随机预言家模型：碰撞问题

Find-Collision(h, Q)

选择 $X_0 \subseteq X, |X_0| = Q$

for each $x \in X_0$

do $y_x \leftarrow h(x)$

if 对某一 $x' \neq x$, 有 $y_x = y_{x'}$

then return(x, x')

else return(failure)

对于任意的 $X_0 \subseteq X$, 且 $|X_0| = Q$, 算法的平均成功率

$$\varepsilon = 1 - \left(\frac{M-1}{M}\right)\left(\frac{M-2}{M}\right)\dots\left(\frac{M-Q+1}{M}\right)$$

$$Q \approx \sqrt{2M \ln \frac{1}{1-\varepsilon}}$$

2022



7、随机预言家模型

- ◆ Hash函数可为数据完整性提供保障，通过给数据附加数字摘要，或称指纹，来检测数据是否被篡改。
- ◆ Hash函数的安全性
 - ◆ 随机预言机可以看做构造Hash函数的理想模型
 - ◆ 在随机预言机模型下定义和分析关于Hash函数的三个安全性问题
 - ◆ 原像问题（单向性）
 - ◆ 第二原像问题
 - ◆ 碰撞问题

2022/4/13